

Доклад на тему

Формальная верификация смарт-контрактов: от спецификации на языке TLA+ до автоматического поиска инвариантов и уязвимостей переполнения

Ахлиддинзода Аслиддин

2026-04-03

Информация

Докладчик

- ▶ Ахлиддинзода Аслиддин
- ▶ НФИМд-01-25
- ▶ студент кафедры теории вероятностей и кибербезопасности
- ▶ Российский университет дружбы народов им. П. Лумумбы
- ▶ 1032259392@rudn.ru
- ▶ <https://github.com/aslidin12>



Проблема и актуальность исследования

Проблема: Уязвимости целочисленного переполнения в DeFi-контрактах приводят к многомиллионным потерям. Ручной аудит и тестирование не дают математических гарантий.

Актуальность: Для надёжной защиты нужна формальная верификация на TLA+ с автоматическим поиском инвариантов — это позволит находить переполнения до развёртывания контракта, без высокой экспертизы.

Объект, предмет, цель и задачи

Объект исследования: Процесс формальной верификации смарт-контрактов

Предмет исследования: Методы спецификации на TLA+ и алгоритмы автоматического поиска инвариантов переполнения

Цель исследования: повысить надёжность контрактов за счёт связки TLA+ и автосинтеза инвариантов

Задачи исследования:

1. Построить TLA+-модели типовых контрактов
2. Разработать алгоритм автоматического поиска инвариантов
3. Реализовать прототип и оценить на реальных уязвимостях

Спецификация смарт-контрактов на TLA+

Контракт как машина состояний

- ▶ Глобальное состояние: `balances`, `allowances`, `totalSupply`
- ▶ Переходы — вызовы функций (`transfer`, `mint`, `swap`)
- ▶ Каждый переход: отношение $\text{State} \rightarrow \text{State}'$

Безопасная арифметика в TLA+

- ▶ Стандартные целые TLA+ не ограничены
- ▶ Моделируем `Uint256`: $0 \dots 2^{256}-1$
- ▶ Операторы `Add256`, `Sub256` — с предусловием
- ▶ При нарушении — переход невозможен (`revert`)

Автоматический поиск инвариантов и уязвимостей переполнения

Алгоритм OverflowHunter+ 1. Статический анализ
TLA+-спецификации — выявляем все арифметические
выражения

2. Генерация кандидатов — шаблоны $\text{expr} \leq \text{MAX}$ $\square$ $\text{expr} \geq 0$
3. CEGIS-цикл

Результаты

- ▶ Обнаружено уязвимостей увеличилось до 94% (было 70%)
- ▶ Среднее время на контракт 2-18 мин (было 45 мин)
- ▶ Ложные срабатывания 8% (было 12%)

Практическая значимость

1. Разработчикам — раннее обнаружение переполнений без экспертизы в формальных методах
2. Аудиторам — исполняемая документация инвариантов
3. CI/CD — интеграция в пайплайн, верификация до деплоя
4. Обучение — наглядные примеры безопасности контрактов

Выводы

1. Построена методология TLA+-спецификации контрактов с учётом разрядности
2. Предложен алгоритм автоматического синтеза инвариантов переполнения
3. Прототип обнаруживает 94% известных уязвимостей при низком времени анализа